Cybersecurity Daily Newsletter

Vol. 007 | 2026-11-02 09:00 WIB

Top 5 Highlights

• Alpine Linux rebuilds GitLab after attempted RCE attack

• [+24h Old] Week in review: Binance hit by $6.3 billion theft, impact of Brotli vulnerability

• [+24h Old] CVSS 10.0 LXD, MicroCloud Flaw Lets Attackers Impersonate Trusted Clients Without a Private Key

• [+24h Old] NetamLoader Malware Targets Government Windows 10 Systems in Asia via .NET Injection

• [+24h Old] Northflank security breach leads to abuse of customers' AI API keys

Threat Intelligence (10)

01. [+24h Old] CVSS 10.0 LXD, MicroCloud Flaw Lets Attackers Impersonate Trusted Clients Without a Private Key

A critical flaw in Canonical's LXD and MicroCloud let an attacker log in as a trusted client without holding that client's private key. To do it, the attacker had to reach their HTTPS API over the network and have the trusted client's public certificate. Once in, the attacker would act as that client, with access to the cluster and its virtual machines. If…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/11/critical-lxd-and-microcloud-flaw-cvss.html

02. [+24h Old] NetamLoader Malware Targets Government Windows 10 Systems in Asia via .NET Injection

Cybersecurity researchers have disclosed details of what has been described as a "highly sophisticated infection chain" targeting government organizations in Asia. The activity, detailed by Kaspersky this week, targeted a custom Windows 10 build used exclusively by government entities in Asia and involves the deployment of a previously undocumented…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/11/netamloader-malware-targets-government.html

03. [+48h Old] Cloudflare Reports 18.2 Million Network-Layer DDoS Attacks in Q3, Up 38%

Threat actors are launching about 8,226 network-layer distributed denial-of-service (DDoS) attacks per hour, Cloudflare revealed Thursday. The web infrastructure and security company said it autonomously mitigated 18.2 million network-layer (L3) DDoS attacks and 14.4 trillion HTTP DDoS requests in the third quarter of 2026. That amounts to 197,400 attacks p…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/cloudflare-reports-182-million-network.html

04. [+48h Old] Inside a malicious Claude Code-branded extension and its persistent SSH backdoor

Microsoft analyzes a malicious Claude Code-branded extension, its persistent SSH backdoor, and guidance to detect and remediate it. The post Inside a malicious Claude Code-branded extension and its persistent SSH backdoor appeared first on Microsoft

Security Blog .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.microsoft.com/en-us/security/blog/2026/10/30/inside-malicious-claude-code-branded-cursor-extension-persistent-ssh-backdoor/

05. [+48h Old] Sophisticated malware targets government-specific windows systems in Asia

As noted by The Record, suspected nation-state hackers have developed sophisticated malware designed to target a customized version of Windows used by government agencies in Asia.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.scworld.com/brief/sophisticated-malware-targets-government-specific-windows-systems-in-asia

06. [+48h Old] Devs Hit by Trojanized Claude Code Extension for Cursor

Two serious security issues hit Cursor on the same day, highlighting the risks for AI-powered integrated development environments (IDEs).

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.darkreading.com/cyberattacks-data-breaches/devs-trojanized-claude-code-extension-cursor

07. [+48h Old] Malicious Claude Code extension on Cursor planted SSH backdoors

A malicious version of Anthropic's Claude Code VS Code extension was distributed through Cursor's extension marketplace for approximately 11 hours on October 29, exposing up to 5,000 developers to malware designed to install persistent SSH backdoors. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/malicious-claude-code-extension-on-cursor-planted-ssh-backdoors/

08. [+48h Old] Passkeys Are Better Than Passwords. But They Are Not Enough.

As organizations eliminate passwords, attackers will adapt. Instead of attacking the authenticator directly, they will look for opportunities around it. The post Passkeys Are Better Than Passwords. But They Are Not Enough. appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.securityweek.com/passkeys-are-better-than-passwords-but-they-are-not-enough/

09. [+48h Old] $2 Million+ Drained From Polymarket Traders in New Supply Chain Attack

Malicious code linked to a website monitoring tool was designed to hijack logged-in Polymarket sessions and siphon user funds. The post $2 Million+ Drained From Polymarket Traders in New Supply Chain Attack appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://www.securityweek.com/2-million-drained-from-polymarket-traders-in-new-supply-chain-attack/

10. [+48h Old] Binance links $6.3 billion crypto theft to compromised DevOps laptop

Binance, the world's largest crypto exchange, has linked the theft of about $6.3 billion in cryptocurrency to a DevOps engineer's compromised laptop. […]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/binance-links-63-billion-crypto-theft-to-compromised-devops-laptop/

Latest Vulnerabilities (10)

01. Alpine Linux rebuilds GitLab after attempted RCE attack

Hackers attempted to exploit a critical GitLab vulnerability in Alpine Linux's development infrastructure on October 20-21, prompting the open-source project to rebuild its GitLab server and reset all passwords over concerns of a possible compromise. […]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/alpine-linux-rebuilds-gitlab-after-attempted-rce-attack/

02. [+24h Old] Week in review: Binance hit by $6.3 billion theft, impact of Brotli vulnerability

Here’s an overview of some of last week’s most interesting news, articles, interviews and videos: r/opensource bans AI projects, and solo devs go down with them Moderators of r/opensource, Reddit’s catch-all forum for open source software, have barred any project that “uses AI, is made by AI, or is intended for AI.” Moderator Wolvereness announced the rules…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.helpnetsecurity.com/2026/11/01/week-in-review-binance-hit-by-6-3-billion-theft-impact-of-brotli-vulnerability/

03. [+24h Old] New Android SMS of Death exploit can remotely crash unpatched phones

A security researcher has released a proof-of-concept exploit for a recently patched Android vulnerability, dubbed "SMS of Death" and tracked as CVE-2026-58882, that lets attackers remotely disrupt cellular service or crash phones by sending a specially crafted text message. […]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/new-android-sms-of-death-exploit-can-remotely-crash-unpatched-phones/

04. [+24h Old] From Beginner to Bug Hunter: Learning Cybersecurity in the AI Era.

AI-generated vulnerability reports are overwhelming some bug bounty programs, making it harder for aspiring security researchers to know where to start. TryHackMe explains how beginners can build practical cybersecurity skills, use AI responsibly, and produce reproducible findings that stand up to scrutiny. […]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/from-beginner-to-bug-hunter-learning-cybersecurity-in-the-ai-era/

05. [+48h Old] Attackers Chain Three Ivanti Connect Secure Flaws to Gain Unauthenticated Root Access

The U.S. Cybersecurity and Infrastructure Security Agency (CISA) on Friday added two security flaws impacting Ivanti Connect Secure (ICS) to its Known Exploited Vulnerabilities (KEV) catalog, following active exploitation in the wild. The vulnerabilities are listed below - CVE-2026-111357 (CVSS score: 8.8) - A missing authentication for a critical function…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://thehackernews.com/2026/10/attackers-chain-three-ivanti-connect.html

06. [+48h Old] Choosing a WAAP in 2026: 3 questions that separate the shortlist

One platform or four Your WAF renewal is coming up. The API team has its own tooling in mind, the fraud team wants a bot product, and someone in networking owns DDoS. Four controls, four consoles, four sets of policies in front of the same applications. That is the situation a Web Application and API Protection platform, or WAAP, exists to replace: one serv…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.csoonline.com/article/4242913/choosing-a-waap-in-2026-3-questions-that-separate-the-shortlist.html

07. [+48h Old] AI-generated code security shows first significant improvement in a year

According to Tech Radar, security in code generated by frontier artificial intelligence models has improved for the first time in a year, with vulnerability rates decreasing from 44% to 38%.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/ai-generated-code-security-shows-first-significant-improvement-in-a-year

08. [+48h Old] Critical Linux kernel flaw allows remote root attacks on MPTCP servers

Security researchers at Anthropic have developed an exploit for a critical Linux kernel vulnerability that allows unauthenticated attackers to remotely execute commands as root on servers running Multipath TCP (MPTCP) listeners. […]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/critical-linux-kernel-flaw-allows-remote-root-attacks-on-mptcp-servers/

09. [+48h Old] Behind the Scenes of How Operation Blackout Went Down

A recent law enforcement operation to dismantle harmful scam centers was a big success. A threat intelligence expert walks us through what happened and why he wants more of the same.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.darkreading.com/cybersecurity-operations/behind-the-scenes-how-operation-blackout-went-down

10. [+48h Old] Drupal Commerce Core access bypass flaw exploited in attacks

Attackers exploit critical Drupal Commerce Core flaw to bypass access controls and manipulate orders.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/news/drupal-commerce-core-access-bypass-flaw-exploited-in-attacks

Data Breach & Cybercrime (10)

01. [+24h Old] Northflank security breach leads to abuse of customers' AI API keys

Cloud application hosting platform Northflank is warning customers to rotate all credentials and secrets stored on its platform after a security breach led to unauthorized use of customers' AI API keys. […]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/northflank-security-breach-leads-to-abuse-of-customers-ai-api-keys/

02. [+24h Old] Chainalysis discloses data breach from "offensive agentic techniques"

Blockchain analytics firm Chainalysis disclosed a data breach after attackers used "offensive agentic techniques" to access internal systems and tools, exposing customer names, email addresses, user IDs, and organizational roles. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/chainalysis-discloses-data-breach-from-offensive-agentic-techniques/

03. [+24h Old] Chainalysis Confirms Intrusion Into Internal Tools and Exposure of Customer Identity Data

American blockchain analysis firm Chainalysis said it was the target of a cybersecurity incident in which an external actor accessed non-sensitive customer data. However, the company noted that the breach did not result in unauthorized access to its investigation content, authentication credentials, or session tokens. "This month, Chainalysis detected an ex...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://thehackernews.com/2026/10/chainalysis-confirms-intrusion-into.html

04. [+48h Old] Crim spent $7K+ on AI services in extortion attacks, then left evidence for all to see

n0n-existent security

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.theregister.com/security/2026/10/30/crim-spent-7k-on-ai-services-in-extortion-attacks-then-left-evidence-for-all-to-see/5306754

05. [+48h Old] New Framework Puts Ransomware Resilience for AI Systems in Focus

RAID-AI aims to help organizations assess their security preparation for ransomware attacks targeting AI systems

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.infosecurity-magazine.com/news/framework-ransomware-resilience-ai/

06. [+48h Old] In Other News: Anthropic Breach Dispute, UEFI Flaw Hits Most Servers, Cloudflare AI Data Leak

Noteworthy stories that might have slipped under the radar: Iran eyed in military freezer hacks, Copenhagen University breach, AI-powered malware. The post In Other News: Anthropic Breach Dispute, UEFI Flaw Hits Most Servers, Cloudflare AI Data Leak appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.securityweek.com/in-other-news-anthropic-breach-dispute-uefi-flaw-hits-most-servers-cloudflare-ai-data-leak/

07. [+48h Old] Bulletproof Host Virtualine Loses Its Domain to FBI Seizure

It allowed customers to host hack-for-hire services, supported ransomware and infostealer operators, and accepted crypto payments. The post Bulletproof Host Virtualine Loses Its Domain to FBI Seizure appeared first on SecurityWeek .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.securityweek.com/bulletproof-host-virtualine-loses-its-domain-to-fbi-seizure/

08. [+48h Old] Binance hit by largest-ever crypto theft, with $6.3 billion stolen

Attackers stole about $6.3 billion in cryptocurrency from Binance in what analysts say is the largest crypto theft on record.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.malwarebytes.com/blog/news/2026/10/binance-hit-by-largest-ever-crypto-theft-with-6-3-billion-stolen

09. [+48h Old] Everyday channels are available in an incident, but you may not want them

The first hours after a serious cyber incident are filled with activity . Security starts investigating, IT works to contain the impact, legal begins assessing potential obligations, and executives want to know what happened and what the company is doing about it. Most teams rely on the same tools they use every day to coordinate that work, which usually me…

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.csoonline.com/article/4242184/everyday-channels-are-available-in-an-incident-but-you-may-not-want-them.html

10. [+48h Old] Binance hit by $6.3 billion theft in what could be the biggest crypto heist on record

About $6.3 billion in cryptocurrency was stolen from Binance in what might be the biggest crypto hack in history. “Binance’s initial investigation suggests that the security incident may involve a compromised DevOps engineer’s laptop, which allowed an attacker to gain access to a service container and submit unauthorized withdrawal transactions,” the exchan…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.helpnetsecurity.com/2026/10/30/binance-crypto-hack/